SIMATS ENGINEERING

CSA6303 – Threat Intelligence and Network Security

A1 – Threat Intelligence Report

Assessment Answers

Subject	Threat Intelligence	**Total Marks**	50
Questions	5 (all compulsory)	**Marks per Question**	10
Reg. No	192465027	**Name**	RESHMA S
Faculty	Dr. V. Parthipan	**Slot**	A

Instructions: *Answer all questions. Support answers with examples and diagrams where appropriate.*

CO3: *Perform threat analysis using intelligence models and utilize industry tools for monitoring and detection.*

Code of Conduct: *I __RESHMA S [192465027] (Name / Reg No) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment. I understand that any violation of academic integrity rules will result in disciplinary action.*

Signature of Student: _____RESHMA S_____

Question 1: Threat Hunting Techniques [10 Marks]

An organization suspects that an attacker has gained unauthorized access to its internal network. The security team observes unusual login times, unexpected processes, and connections to unfamiliar external servers. Describe the proactive threat-hunting techniques you would use to investigate the activity and identify potential threats.

1. Introduction

Threat hunting is the proactive, human-led search for adversaries that have evaded automated defences. Rather than waiting for an alert, the hunter assumes a breach has occurred and looks for evidence of it. The three observed symptoms (odd login times, unexpected processes and unfamiliar external connections) form the starting point of the hunt.

2. Hunting Approach

2.1 Hypothesis-driven hunting

Form a testable hypothesis, for example: "An attacker is using stolen credentials to log in after hours, run a remote-access tool and beacon to a command-and-control (C2) server." Map it to MITRE ATT&CK techniques (Valid Accounts T1078, Command and Scripting Interpreter T1059, Application Layer Protocol T1071) and search for evidence of each.

2.2 Core techniques

Technique	What the hunter does	Example for this scenario
Intel-driven hunting	Search logs for known IOCs (IPs, domains, hashes) from threat-intelligence feeds.	Check firewall/DNS logs for the unfamiliar external IPs against feeds such as VirusTotal, AlienVault OTX, MISP.
Behavioural / anomaly hunting	Baseline normal behaviour and look for deviations.	Compare login times per user with their 30-day baseline; flag 2–4 AM logins and impossible travel.
Stacking / frequency analysis	Count occurrences and examine the rare ones (long-tail analysis).	Stack process names and parent-child pairs across hosts; a process on only 1–2 hosts is suspicious.
Beaconing analysis	Detect regular, periodic outbound connections.	Look for connections at fixed intervals (e.g., every 60 s) with small, uniform payloads.
Credential-abuse hunting	Review authentication logs for brute force, password spraying and lateral movement.	Event IDs 4624/4625/4648/4672 on Windows; many failures followed by a success.
Endpoint forensics	Inspect processes, persistence and memory on suspect hosts.	Check scheduled tasks, Run keys, services, PowerShell history, unsigned binaries.

3. Step-by-Step Investigation

- **Scope and collect data:** Gather authentication logs (AD, VPN), endpoint telemetry (Sysmon, EDR), DNS, proxy and NetFlow data into a SIEM.
- **Analyse logins:** Identify accounts with off-hours logins, new source IPs or devices, and privileged accounts used unusually.
- **Analyse processes:** Look for LOLBins (powershell.exe, wmic.exe, rundll32.exe), processes launched from temp/user directories, and odd parent-child chains such as winword.exe → cmd.exe.
- **Analyse network traffic:** Resolve unfamiliar IPs/domains, check reputation, domain age and DGA-like names; inspect volume, ports and TLS certificates.
- **Pivot and correlate:** Link a suspicious login to the process it launched and the outbound connection it created; trace laterally to other hosts.
- **Confirm and contain:** If malicious, isolate hosts, disable accounts, block IOCs and escalate to incident response.
- **Document and improve:** Record findings, convert them into detection rules, and update the hunt playbook.

4. Conclusion

By combining hypothesis-driven, intel-driven and anomaly-based hunting, and pivoting between identity, endpoint and network data, the team can confirm the compromise, determine its scope and convert findings into lasting detections.

Question 2: SIEM Tools and Security Monitoring [10 Marks]

A company implements a SIEM system to monitor its network. The system generates multiple alerts about suspicious login attempts and unusual outbound connections. Explain how the SIEM system can collect and analyze security events, correlate alerts, and help security analysts prioritize potential threats.

1. Introduction

A Security Information and Event Management (SIEM) platform centralises log data from across the environment, normalises it, applies detection logic and presents prioritised alerts to analysts. Examples include Splunk Enterprise Security, IBM QRadar, Microsoft Sentinel and the ELK/Elastic Security stack.

2. Event Collection

- **Sources:** Firewalls, IDS/IPS, servers, Active Directory, VPN, endpoints/EDR, cloud services, DNS and proxy logs.
- **Methods:** Agents/forwarders (e.g., Splunk Universal Forwarder, Beats), Syslog, WMI/Windows Event Forwarding, APIs and NetFlow.
- **Processing:** Parsing, normalisation to a common schema, timestamp synchronisation and enrichment (GeoIP, asset owner, threat-intel tags).
- **Storage:** Indexed hot storage for fast search and archived storage for compliance and forensics.

3. Event Analysis and Correlation

The SIEM analyses events using rules, statistics and behavioural models. Correlation links individually minor events into a single meaningful incident.

Correlation type	Description	Example
Rule-based	If A and B occur within time T, raise an alert.	10 failed logins followed by a success from the same IP within 5 minutes.
Cross-source	Join events from different systems.	VPN login from a new country + large outbound transfer from that user's workstation.
Threshold / statistical	Alert when counts exceed a baseline.	Outbound bytes 5× the daily average.
Behavioural (UEBA)	Detect deviation from a user or entity profile.	Account used at 3 AM for the first time.
Threat-intel match	Compare events to known IOCs.	Outbound connection to an IP on a C2 blocklist.

4. Alert Prioritisation

- **Risk scoring:** Combine severity, asset criticality (e.g., domain controller vs. kiosk), user privilege and threat-intel confidence into a score.
- **Deduplication and grouping:** Merge repeated alerts of the same pattern into one incident to reduce alert fatigue.
- **Context enrichment:** Show asset owner, vulnerability status, previous incidents and MITRE ATT&CK mapping.
- **False-positive tuning:** Whitelist known scanners and admin tools; refine thresholds.
- **Dashboards and workflow:** Priority queues, ticketing integration, and SOAR playbooks for automated enrichment or blocking.

5. Application to the Scenario

The suspicious logins and unusual outbound connections are correlated by user, host and time window. If the same account that shows a password-spraying pattern later generates traffic to a flagged external IP, the SIEM raises one high-priority incident rather than many separate alerts, allowing the analyst to investigate, contain and report quickly.

Question 3: Security Monitoring and Anomaly Detection [10 Marks]

A company's security monitoring dashboard identifies a sudden increase in outbound network traffic during non-working hours. The activity originates from a database server that normally transfers only small amounts of data. Explain how you would investigate the anomaly, identify possible data exfiltration, and recommend suitable monitoring and prevention measures.

1. Introduction

Large outbound transfers from a database server outside business hours are a classic indicator of data exfiltration (MITRE ATT&CK TA0010). The goal is to verify whether the traffic is legitimate (backup, replication, batch job) or malicious, and to limit data loss quickly.

2. Investigation Steps

- **Validate the alert:** Confirm the NetFlow/firewall figures, time window, destination IP/port and bytes transferred against the server's baseline.
- **Rule out legitimate causes:** Check change tickets, backup and ETL schedules, replication jobs and with the DBA team.
- **Identify the destination:** Resolve the external IP, check reputation, geolocation, ASN and hosting type (cloud storage, VPS, Tor exit node).
- **Examine the server:** Review running processes, new services, scheduled tasks, installed tools (e.g., rclone, scp, curl), and recent logins and privilege changes.
- **Review database activity:** Audit logs for large SELECT queries, dumps (mysqldump, bcp), export commands and access by unusual accounts.
- **Inspect traffic:** Use packet capture or proxy logs to see protocol, encryption, compression or encoding, DNS tunnelling and unusual ports.
- **Assess the data:** Identify which tables or files were accessed and whether they contain PII, financial or regulated data.
- **Contain:** If malicious: isolate the server, block the destination, revoke credentials and preserve evidence (disk and memory images).

3. Indicators of Data Exfiltration

- Large or sustained outbound transfers at odd hours to a new external destination.
- Staging activity: archives (.zip, .rar, .7z) created in temp directories.
- Use of unusual protocols, or DNS or ICMP tunnelling.
- Database queries that return far more rows than normal, or access from a service account interactively.

4. Monitoring and Prevention Measures

Control	Purpose / Implementation
Baseline and anomaly alerts	SIEM/NDR rules for outbound volume per host and per time of day (e.g., Splunk, Elastic, Darktrace).
Data Loss Prevention (DLP)	Inspect and block sensitive data leaving the network via email, web and endpoints.
Egress filtering	Default-deny outbound rules; allow only required destinations and ports; proxy with TLS inspection.
Database Activity Monitoring	Real-time auditing of queries, exports and privileged access.
Network segmentation	Place databases in a restricted zone with no direct internet access.
Least privilege and MFA	Limit database and admin accounts; rotate service-account credentials.
Encryption and tokenisation	Reduce the value of stolen data.
EDR and logging	Endpoint detection on the server; centralised log retention.
Incident response plan	Defined playbook for exfiltration, including legal and breach-notification steps.

Question 4: Tools Used in the IT Industry for Threat Hunting [10 Marks]

An IT organization suspects that malware has infected several employee workstations. The security team has access to SIEM software, endpoint detection tools, network traffic analyzers, and vulnerability scanners. Select suitable tools for investigating the incident and explain how each tool can help identify, analyze, and contain the threat.

1. Introduction

An effective malware investigation uses complementary tools: the SIEM provides the wide view, endpoint tools give host-level depth, network analysers reveal communications, and vulnerability scanners explain how the infection may have occurred.

2. Tool Selection and Roles

Tool category	Examples	Identify / Analyse	Contain / Prevent
SIEM	Splunk, IBM QRadar, Microsoft Sentinel, ELK	Correlate alerts across workstations; search for shared IOCs, common user, time and malicious domain.	Trigger alerts and SOAR playbooks (disable account, block IP); keep evidence for reporting.
Endpoint Detection and Response (EDR)	CrowdStrike Falcon, Microsoft Defender for Endpoint, SentinelOne, Sysmon	View process trees, file and registry changes, persistence, and memory artefacts; hash and sandbox suspicious files.	Network-isolate hosts, kill processes, quarantine files and roll back changes remotely.
Network traffic analysers	Wireshark, Zeek, Suricata, Snort, NetFlow tools	Detect C2 beaconing, DNS anomalies, malicious downloads and lateral SMB/RDP traffic.	Create IPS rules; block malicious IPs/domains at firewall and DNS.
Vulnerability scanners	Nessus, Qualys, OpenVAS	Find unpatched software, weak configurations and missing patches that malware exploited; locate other exposed hosts.	Prioritise and apply patches; harden configurations to prevent reinfection.
Threat-intel / sandbox (supporting)	VirusTotal, MISP, Any.Run, Cuckoo	Check hashes, URLs and domains; observe malware behaviour safely.	Feed new IOCs back to SIEM, EDR and firewall.

3. Workflow

- **Identify:** SIEM alerts and EDR telemetry show which workstations share the same suspicious file, process or domain.
- **Analyse:** EDR provides host evidence; Wireshark/Zeek confirms C2 traffic; hashes and domains are checked with threat intelligence and a sandbox.
- **Contain:** Isolate infected endpoints through EDR, block IOCs on firewall/proxy/DNS, and disable compromised accounts.
- **Eradicate and recover:** Remove persistence, reimage if needed, patch vulnerabilities found by the scanner, and restore from clean backups.
- **Lessons learned:** Create new detection rules and update user-awareness training.

Question 5: Integrated Threat Hunting and Incident Reporting [10 Marks]

A company detects suspicious user logins, connections to a malicious domain, and an unknown process running on an employee workstation. The security team uses Splunk or the ELK Stack to analyze logs and a threat intelligence platform to verify suspicious indicators. Describe the complete threat-hunting process, including data collection, log correlation, threat investigation, malware analysis if required, risk assessment, and preparation of a threat-hunting report with recommended remediation actions.

1. Introduction

This answer describes an end-to-end hunt that moves from raw data to a final report, using Splunk/ELK for log analysis and a threat-intelligence platform (TIP) such as MISP, VirusTotal or AlienVault OTX for indicator verification.

2. Threat-Hunting Process

Step 1: Data Collection

Ingest Windows Security and Sysmon logs, VPN and Active Directory authentication logs, DNS, proxy and firewall logs, and EDR telemetry into Splunk (via Universal Forwarder) or ELK (via Beats/Logstash). Normalise fields and synchronise time.

Step 2: Log Correlation

- Join the suspicious logins, the DNS/proxy hits to the malicious domain and the unknown process by user, host and timestamp.
- Example Splunk-style search: failed then successful logins by user, followed by process creation on the same host within 30 minutes.
- Build a timeline: initial access → execution → C2 connection.

Step 3: Indicator Verification

Submit the domain, IPs and file hashes to the TIP to check reputation, first-seen date, associated malware families and campaigns. Enrich the results in the SIEM and note confidence levels.

Step 4: Threat Investigation

- Trace the unknown process: path, signer, command line, parent process, network connections and persistence (Run keys, scheduled tasks).
- Review the user's activity: source of logins, mailbox (phishing), downloads, and other accounts or hosts accessed.
- Hunt for the same IOCs across the whole environment to find other affected systems (scoping).

Step 5: Malware Analysis (if required)

- **Static analysis:** hashes, strings, PE headers, imports, packing (PEStudio, strings, YARA).
- **Dynamic analysis:** execute in an isolated sandbox (Cuckoo, Any.Run) and observe file, registry and network behaviour.

- **Memory analysis:** extract injected code and artefacts (Volatility).
- **Output:** new IOCs, family attribution and YARA/Sigma detection rules.

Step 6: Risk Assessment

Factor	Consideration
Asset value	Role of the workstation and data it can access.
Impact	Confidentiality, integrity and availability effects; regulatory exposure.
Likelihood / spread	Evidence of lateral movement or other infected hosts.
Threat actor capability	Commodity malware vs. targeted attack, based on TIP data.
Overall rating	Low / Medium / High / Critical to set response urgency.

Step 7: Containment and Eradication

Isolate the workstation, block the domain/IPs, reset credentials, remove persistence, reimage if necessary and patch exploited weaknesses.

3. Threat-Hunting Report

Report section	Content
Executive summary	Brief, non-technical overview of what happened, impact and status.
Scope and objectives	Hypothesis, systems, data sources and time period covered.
Methodology and tools	Splunk/ELK queries, TIP, sandbox, EDR used.
Findings and timeline	Chronology of events with evidence (screenshots, log excerpts).
Indicators of Compromise	IPs, domains, hashes, file paths, registry keys, user accounts.
MITRE ATT&CK mapping	Techniques observed (e.g., T1078, T1059, T1071).
Risk assessment	Severity, affected assets, business impact.
Recommendations	Short-term and long-term remediation (below).
Appendices	Queries, detection rules, malware analysis details.

4. Recommended Remediation Actions

- **Immediate:** isolate hosts, block IOCs, disable/reset compromised accounts, remove malware.
- **Short term:** patch systems, enforce MFA, deploy new SIEM detection rules and EDR policies.
- **Long term:** user security awareness training, network segmentation, least privilege, regular hunts and tabletop exercises, and periodic review of the incident-response plan.

5. Conclusion

An integrated hunt that combines log correlation, verified threat intelligence, malware analysis and structured reporting not only resolves the current incident but also strengthens future detection and response.